PRACTICAL 3: ALERT TRIAGE PRACTICE

1. Objective

The objective of this exercise is to perform alert triage using Wazuh, analyze authentication-related security events, validate indicators of compromise (IOCs) using threat intelligence platforms, and correlate SIEM alerts with system logs to identify potential attack patterns.

2. Tools Used

The following tools and data sources were utilized during this practical:

* Wazuh for alert monitoring and analysis
* VirusTotal for IOC reputation checks
* AlienVault OTX for threat intelligence validation
* Ubuntu system logs (`/var/log/auth.log`) for evidence correlation

3. Alert Overview

During the monitoring period, multiple authentication-related alerts were observed in Wazuh. These included failed login attempts, repeated password failures, and successful privilege escalation through sudo.

Summary of key alerts:

Alert ID	Description	Priority
001	PAM: User login failed	Medium
002	Multiple password failures	Medium
003	Successful sudo to ROOT executed	High

4. Alert Analysis

The alerts indicate a pattern of authentication misuse within the system. Multiple failed login attempts suggest credential guessing activity, while successful execution of sudo commands confirms privilege escalation behavior.

Although these events originated locally, they replicate real-world attack techniques such as brute-force login attempts followed by privilege escalation.

5. MITRE ATT&CK Mapping

The observed activities were mapped to the following techniques from the MITRE ATT&CK framework:

* Credential Access: MITRE ATT&CK T1110.001
* Privilege Escalation: MITRE ATT&CK T1548

This mapping confirms that the activity aligns with known adversarial behaviors.

6. IOC Validation

Observed Indicators

The following indicators were extracted during analysis:

* Source IP: 127.0.0.1 (localhost)
* Activity: Repeated SSH authentication failures
* User: Invalid login attempts (test user)

Threat Intelligence Analysis

The identified indicators were analyzed using external threat intelligence platforms.

Using VirusTotal, the IP address (127.0.0.1) was checked. No malicious reputation was found, as this address represents a local loopback interface and is not associated with external network activity.

Similarly, AlienVault OTX did not return any matching threat intelligence. This is expected because the activity originated from a local system and is not part of global threat feeds.

Interpretation

Although no external IOC matches were identified, the behavioral pattern of repeated authentication failures clearly aligns with brute-force attack techniques. This demonstrates that not all security incidents rely on external indicators and may require internal log analysis for validation.

7. SSH Brute Force Evidence

Further validation was performed using system logs located at `/var/log/auth.log`.

The logs revealed:

* Multiple failed login attempts for an invalid user

* Repeated password authentication failures
* Connection termination after multiple unsuccessful attempts

These findings confirm the successful simulation of a brute-force attack against the SSH service.

8. SIEM Limitation Analysis

Despite the presence of brute-force activity, Wazuh did not generate a dedicated high-severity alert. This limitation can be attributed to several factors:

* The activity originated from a local IP address (127.0.0.1)
* Alert thresholds for brute-force detection were not met
* Events were logged individually but not correlated into a single attack pattern

This highlights the importance of manual log analysis in SOC operations.

9. Risk Assessment

The overall risk associated with this activity is assessed as **Medium**.

While no external attacker was identified, the presence of repeated authentication failures and successful privilege escalation indicates potential security weaknesses that could be exploited in a real-world scenario.

10. Final Decision

The activity is classified as a **simulated internal attack scenario** involving credential access and privilege escalation.

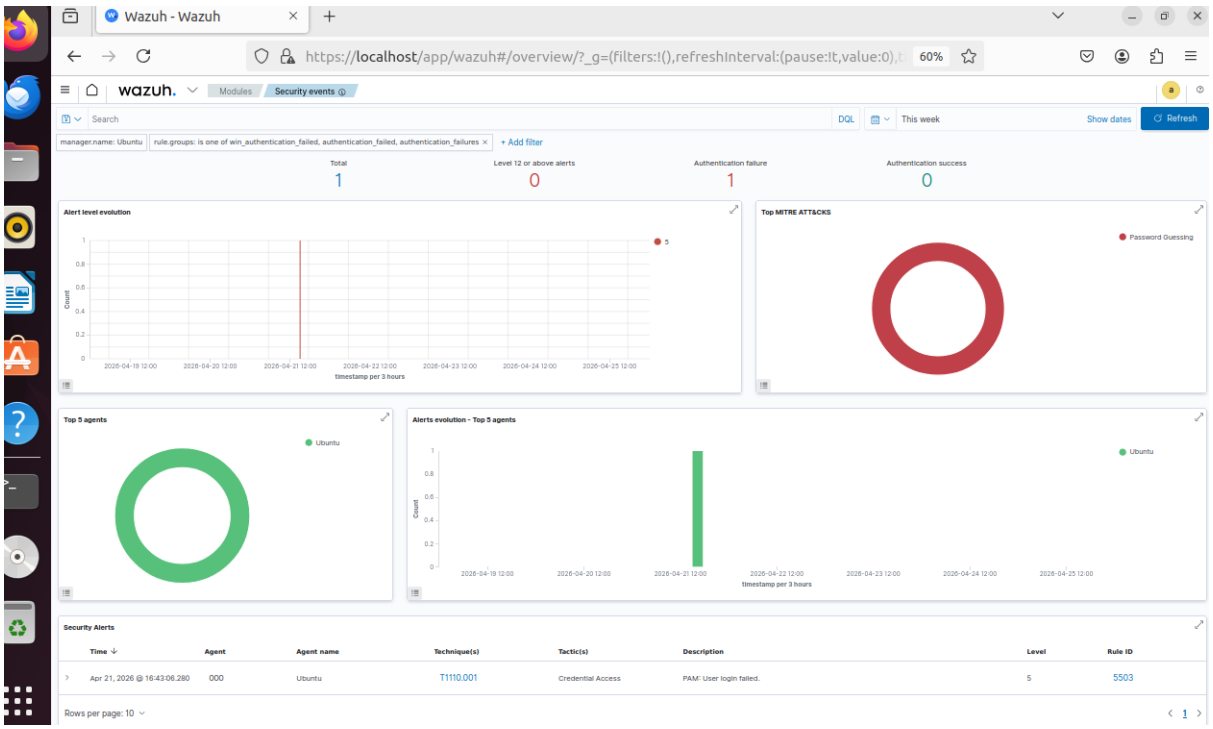
No immediate remediation is required; however, continued monitoring and improved alert correlation rules are recommended.

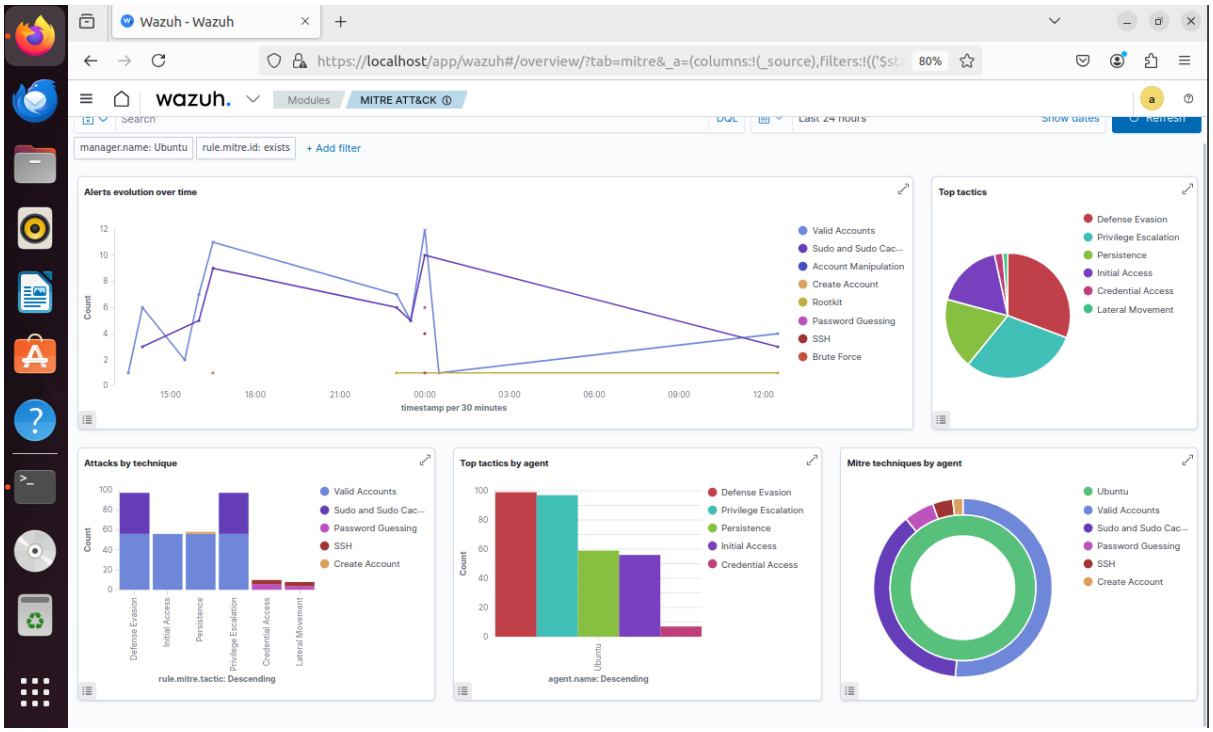
11. Conclusion

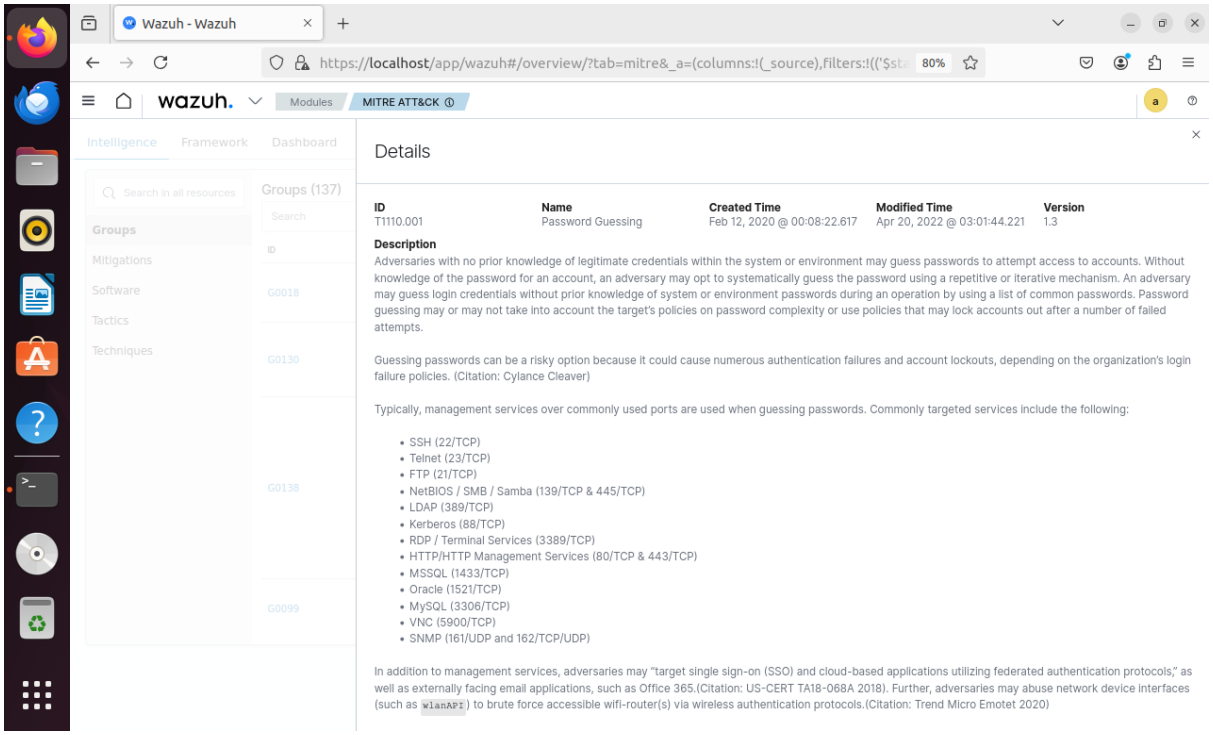
This practical demonstrated the process of alert triage using Wazuh and the importance of correlating SIEM alerts with system logs. Although external threat intelligence tools did not provide matches, internal evidence confirmed brute-force and privilege escalation behavior.

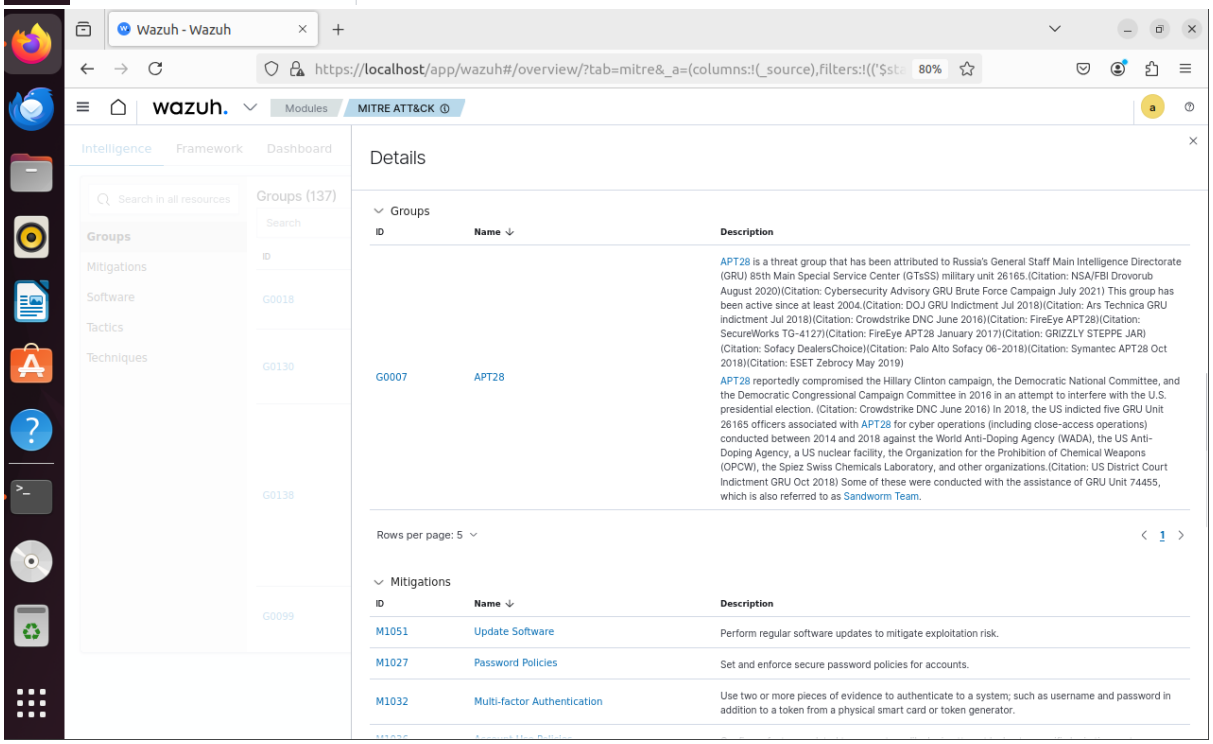
The exercise highlights a key SOC principle: effective incident analysis often depends on combining SIEM data, endpoint logs, and analyst judgment rather than relying solely on automated alerts.

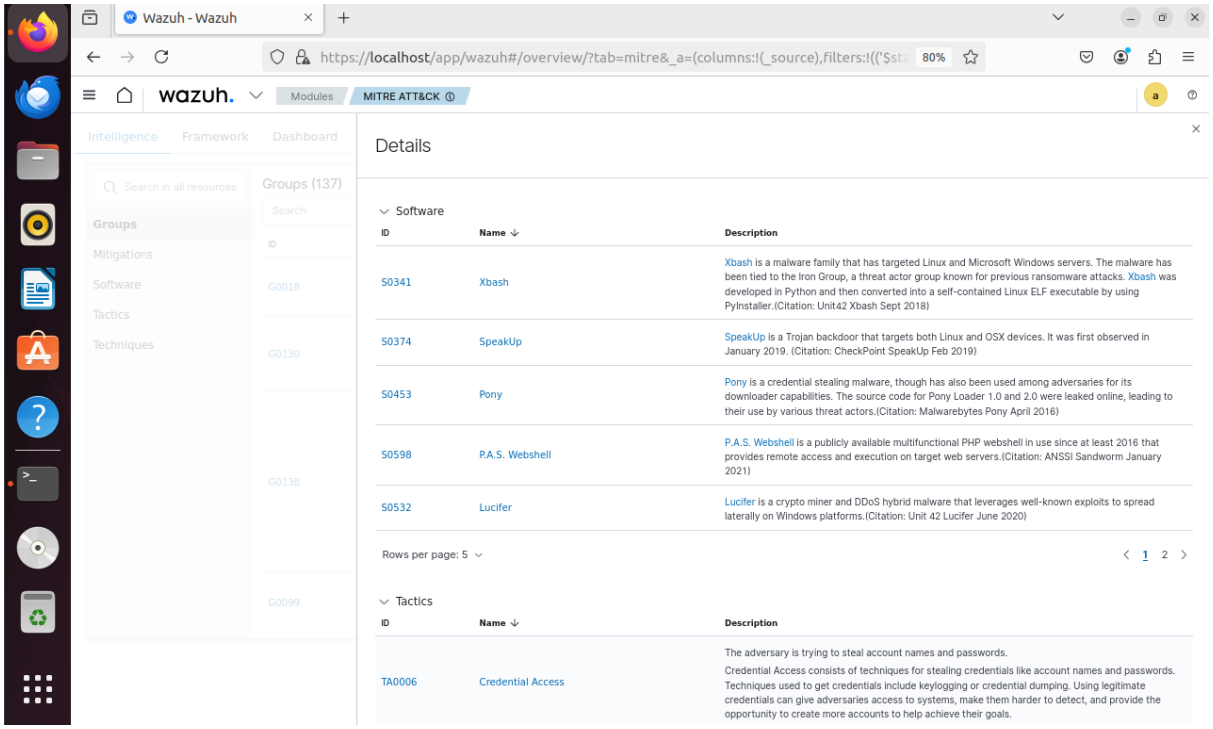
Screenshots:






Wazuh - Wazuh
https://localhost/app/wazuh#/overview/?tab=mitre&_a=(columns:!(_source),filters:!(('$sta
80%
wazuh.
Modules
MITRE ATT&CK
Intelligence
Framework
Dashboard
Search in all resources
Groups (137)
Groups
Mitigations
Software
Tactics
Techniques
Search
ID
G0018
G0130
G0138
G0099
Details
ID
T1110.001
Name
Password Guessing
Created Time
Feb 12, 2020 @ 00:08:22.617
Modified Time
Apr 20, 2022 @ 03:01:44.221
Version
1.3
Description
Adversaries with no prior knowledge of legitimate credentials within the system or environment may guess passwords to attempt access to accounts. Without knowledge of the password for an account, an adversary may opt to systematically guess the password using a repetitive or iterative mechanism. An adversary may guess login credentials without prior knowledge of system or environment passwords during an operation by using a list of common passwords. Password guessing may or may not take into account the target's policies on password complexity or use policies that may lock accounts out after a number of failed attempts.
Guessing passwords can be a risky option because it could cause numerous authentication failures and account lockouts, depending on the organization's login failure policies. (Citation: Cylance Cleaver)
Typically, management services over commonly used ports are used when guessing passwords. Commonly targeted services include the following:
• SSH (22/TCP)
• Telnet (23/TCP)
• FTP (21/TCP)
• NetBIOS / SMB / Samba (139/TCP & 445/TCP)
• LDAP (389/TCP)
• Kerberos (88/TCP)
• RDP / Terminal Services (3389/TCP)
• HTTP/HTTP Management Services (80/TCP & 443/TCP)
• MSSQL (1433/TCP)
• Oracle (1521/TCP)
• MySQL (3306/TCP)
• VNC (5900/TCP)
• SNMP (161/UDP and 162/TCP/UDP)
In addition to management services, adversaries may "target single sign-on (SSO) and cloud-based applications utilizing federated authentication protocols," as well as externally facing email applications, such as Office 365.(Citation: US-CERT TA18-068A 2018). Further, adversaries may abuse network device interfaces (such as wlanAPI) to brute force accessible wifi-router(s) via wireless authentication protocols.(Citation: Trend Micro Emotet 2020)


Wazuh - Wazuh
https://localhost/app/wazuh#/overview/?tab=mitre&_a=(columns:!(_source),filters:!(('$sta
80%
wazuh.
Modules
MITRE ATT&CK
Intelligence
Framework
Dashboard
Search in all resources
Groups (137)
Groups
Mitigations
Software
Tactics
Techniques
Details
Groups
ID
Name
Description
G0007
APT28
APT28 is a threat group that has been attributed to Russia's General Staff Main Intelligence Directorate (GRU) 85th Main Special Service Center (GTsSS) military unit 26165.(Citation: NSA/FBI Drovorub August 2020)(Citation: Cybersecurity Advisory GRU Brute Force Campaign July 2021) This group has been active since at least 2004.(Citation: DOJ GRU Indictment Jul 2018)(Citation: Ars Technica GRU indictment Jul 2018)(Citation: Crowdstrike DNC June 2016)(Citation: FireEye APT28)(Citation: SecureWorks TG-4127)(Citation: FireEye APT28 January 2017)(Citation: GRIZZLY STEPPE JAR)(Citation: Sofacy DealersChoice)(Citation: Palo Alto Sofacy 06-2018)(Citation: Symantec APT28 Oct 2018)(Citation: ESET Zebrocy May 2019)
APT28 reportedly compromised the Hillary Clinton campaign, the Democratic National Committee, and the Democratic Congressional Campaign Committee in 2016 in an attempt to interfere with the U.S. presidential election. (Citation: Crowdstrike DNC June 2016) In 2018, the US indicted five GRU Unit 26165 officers associated with APT28 for cyber operations (including close-access operations) conducted between 2014 and 2018 against the World Anti-Doping Agency (WADA), the US Anti-Doping Agency, a US nuclear facility, the Organization for the Prohibition of Chemical Weapons (OPCW), the Spiez Swiss Chemicals Laboratory, and other organizations.(Citation: US District Court Indictment GRU Oct 2018) Some of these were conducted with the assistance of GRU Unit 74455, which is also referred to as Sandworm Team.
Rows per page: 5
1
Mitigations
ID
Name
Description
M1051
Update Software
Perform regular software updates to mitigate exploitation risk.
M1027
Password Policies
Set and enforce secure password policies for accounts.
M1032
Multi-factor Authentication
Use two or more pieces of evidence to authenticate to a system; such as username and password in addition to a token from a physical smart card or token generator.


Wazuh - Wazuh
https://localhost/app/wazuh#/overview/?tab=mitre&_a=(columns:!(_source),filters:!(('$sta
80%
wazuh.
Modules
MITRE ATT&CK
Intelligence
Framework
Dashboard
Search in all resources
Groups (137)
Groups
Mitigations
Software
Tactics
Techniques
Search
ID
G0018
G0130
G0138
G0099
Details
Software
ID
Name
Description
S0341
Xbash
Xbash is a malware family that has targeted Linux and Microsoft Windows servers. The malware has been tied to the Iron Group, a threat actor group known for previous ransomware attacks. Xbash was developed in Python and then converted into a self-contained Linux ELF executable by using PyInstaller.(Citation: Unit42 Xbash Sept 2018)
S0374
SpeakUp
SpeakUp is a Trojan backdoor that targets both Linux and OSX devices. It was first observed in January 2019. (Citation: CheckPoint SpeakUp Feb 2019)
S0453
Pony
Pony is a credential stealing malware, though has also been used among adversaries for its downloader capabilities. The source code for Pony Loader 1.0 and 2.0 were leaked online, leading to their use by various threat actors.(Citation: Malwarebytes Pony April 2016)
S0598
P.A.S. Webshell
P.A.S. Webshell is a publicly available multifunctional PHP webshell in use since at least 2016 that provides remote access and execution on target web servers.(Citation: ANSSI Sandworm January 2021)
S0532
Lucifer
Lucifer is a crypto miner and DDoS hybrid malware that leverages well-known exploits to spread laterally on Windows platforms.(Citation: Unit 42 Lucifer June 2020)
Rows per page: 5
1
2
Tactics
ID
Name
Description
TA0006
Credential Access
The adversary is trying to steal account names and passwords.
Credential Access consists of techniques for stealing credentials like account names and passwords. Techniques used to get credentials include keylogging or credential dumping. Using legitimate credentials can give adversaries access to systems, make them harder to detect, and provide the opportunity to create more accounts to help achieve their goals.